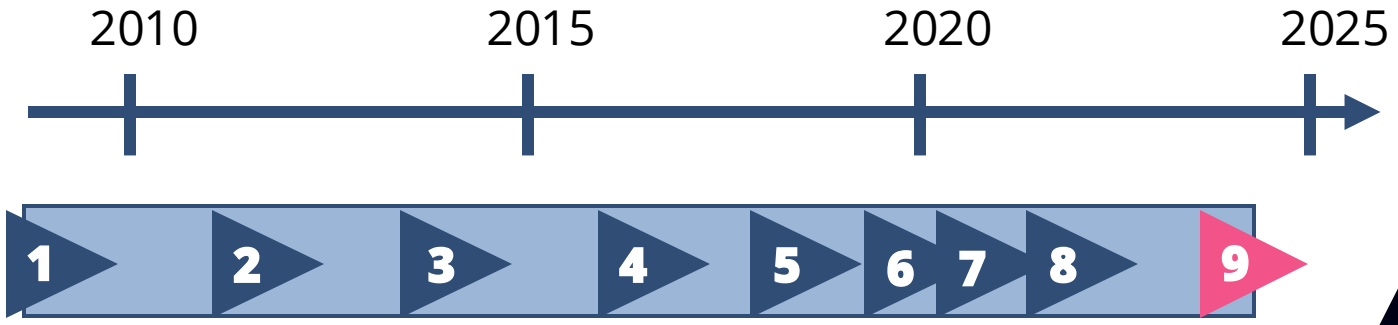
DevSecOps principles

DevSecOps timeline

1. DevOps term created in 2009.
2. Security integration with DevOps, DevSecOps manifesto emerges in 2012.
3. CI/CD adoption intensifies in 2014.
4. DevSecOps term adopted by industry in 2016.
5. Security automation emerges in 2018.
6. DevSecOps adoption intensifies in 2019.
7. ML used with DevSecOps 2021
8. DevOps becomes a strategic imperative 2023
9. GenAI used with DevSecOps.





Copyright© 2025 PeopleCert International Ltd.

DevSecOps

"The purpose and intent of DevSecOps, is to build on the mindset that 'everyone is responsible for security' with the goal of safely distributing security decisions at speed and scale to those who hold the highest level of context without sacrificing the safety required."

Shannon Lietz, Founder of DevSecops.org



Copyright© 2025 PeopleCert International Ltd.

DevSecOps manifesto

- **Lean security:** "We value protecting the organization and customer above checking security boxes."
- **Pragmatic risk acceptance:** "We value focusing on the biggest risks above all else."
- **Transparency:** "We value sharing threat information over keeping it secret."
- **Continuous security:** "We value integrating security into the entire development process above bolting it on afterward."
- **Culture of security:** "We value security practitioners enabling developers over trying to operate as a gatekeeper."

Source: https://www.devsecops.org/

Copyright© 2025 PeopleCert International Ltd.

DevSecOps strategy

"This strategy underscores proactive security practices, embedding security considerations into the entire software life cycle, essential for maintaining software integrity and trust."

Marc Hornbeek
Author: *Continuous Testing, Quality, Security and Feedback*

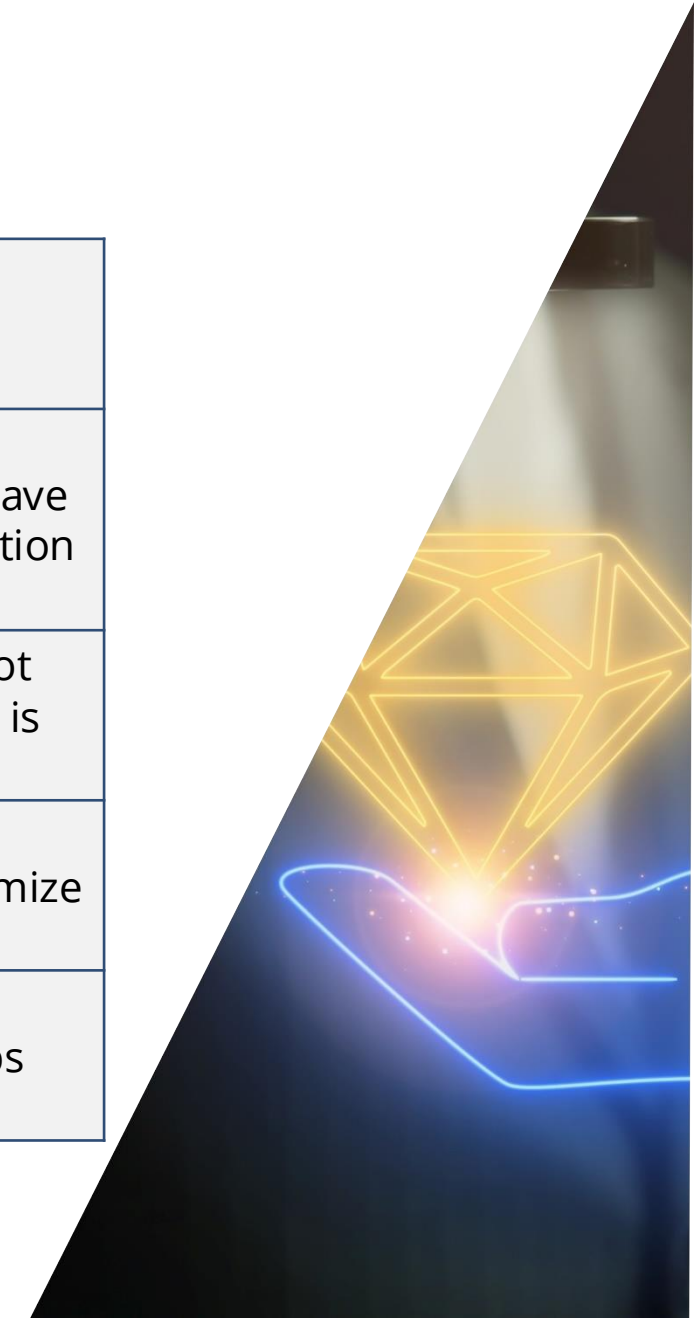
Continuous security (DevSecOps) is a strategy that integrates security measures into continuous development, delivery, and operations to reduce the frequency and impact of security events, measured by security events and security event resolution times.



Copyright© 2025 PeopleCert International Ltd.

CALMS and DevSecOps

Culture	All technology teams have accountability for security; security is everybody's job. All understand the end-to-end system and collaborate regularly to create trust.
Automation	Automation helps assure security by strategic use of codifying the orchestration and automation of tasks and processes that have security vulnerabilities when done manually and where automation can enhance security practices.
Lean	Security is not a constraint in the value stream and teams are not waiting for security activities to happen; flow is optimized. Work is visible through shared backlogs.
Measurement	Cost of breach is understood, business and attack metrics are shared, and a value stream-centric approach is followed to optimize cycle time and ensure no delays caused by security.
Sharing	Security and software engineers cross-skill and collaborate to automate knowledge. Stories are shared through wikis, standups and on a day-to-day basis.



Copyright© 2025 PeopleCert International Ltd.

The Three Ways

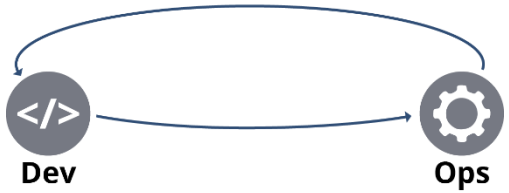
The first way:
Systems thinking



Flow

Ensure that security is not a constraint in the flow of work, shift security testing as far left as possible and automate. Use pre-blessed security libraries, think like a value stream and create mutual accountability.

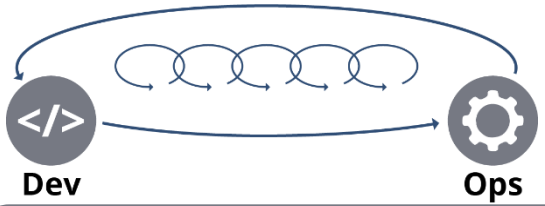
The second way:
Amplify feedback loops



Feedback

Ensure fast feedback by automating security testing, including security early in the process, including them in product demos and creating a continuous peer-to-peer conversation. Use telemetry and observability.

The third way:
Culture of continual experimentation and learning



Continuous experimentation and learning

Ensure the security people and software engineers are cross-skilling. Allocate time for them to sit and work together to learn from each other. Encourage the documenting and sharing of experiences, good and bad.



Copyright© 2025 PeopleCert International Ltd.

DevSecOps principles

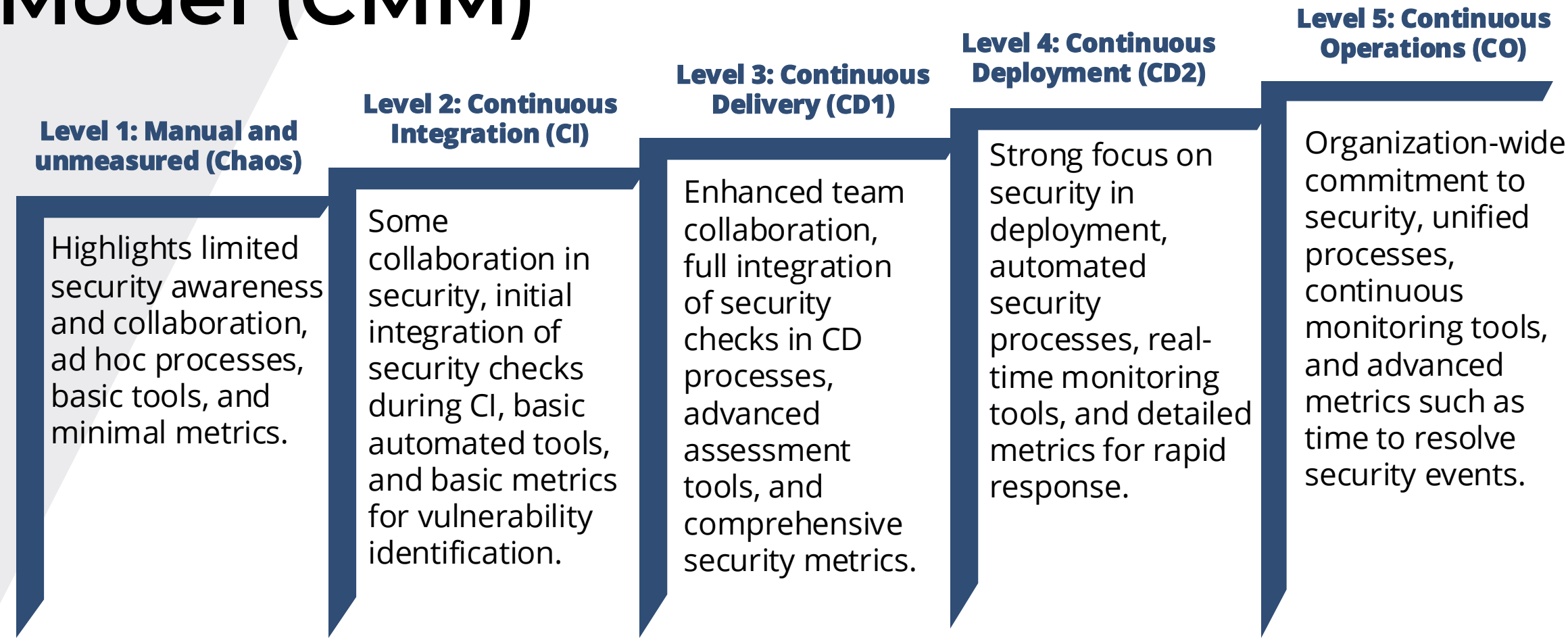
- **DevSecOps culture:** collaboration between development, security, and operations enhances security outcomes.
- **Security awareness and training:** security is a shared responsibility and requires awareness at all levels.
- **Security integration in the life cycle:** security is an integral part of the entire software life cycle, not an isolated stage.
- **Automated security testing:** automation is key to maintaining continuous security vigilance.
- **Proactive risk management:** proactive identification and mitigation of risks are more effective than reactive measures.
- **Rapid incident response:** principle; quick and effective response to security incidents minimizes their impact.
- **Continuous monitoring and compliance:** ongoing monitoring and adherence to compliance standards are critical to maintain security.
- **Feedback and continuous improvement:** feedback is essential for the evolution and improvement of security practices.



Source: *Continuous Testing, Quality, Security and Feedback, by Marc Hornbeek* https://mybook.to/HtAAS8

Copyright© 2025 PeopleCert International Ltd.

DevSecOps Capability Maturity Model (CMM)



Source: *Continuous Testing, Quality, Security and Feedback, by Marc Hornbeek*
https://mybook.to/HtAAS8

Copyright© 2025 PeopleCert International Ltd.